SecureAccess Privacy

Miguel de Valverde Bento
Nº 101018
mvboe1@iscte-iul.pt

Josué Lopes da Glória
Nº 134449
jlgas@iscte-iul.pt

Luís Carlos Lourenço
Nº 110942
lcmlo@iscte-iul.pt

Ricardo de Carvalho Ourelo
Nº 120141
rcooo2@iscte-iul.pt

Daniel Morgado
Nº 98598
Daniel_Morgado@iscte-iul.pt

***Resumo*—O projeto SecureAccess Privacy tem como principal objetivo alargar o protótipo de autenticação SecureAccess com fortes princípios de privacidade de dados. Integrando o conceito de *Privacy by Design*, o sistema não só mantém as características de segurança (MFA, TOTP), como introduz a minimização de dados, controlo de acesso por perfis, retenção limitada e transparência para o utilizador, em alinhamento com as diretrizes do RGPD e melhores práticas do setor.**

***Index Terms*—privacidade, autenticação, multifator, segurança, rgpd, gestão de identidades**

I. Contextualização

O projeto SecureAccess Privacy parte do SecureAccess [1], um protótipo web desenvolvido pelo grupo em Flask, que permite o registo e a autenticação de utilizadores através de password e autenticação multifator (MFA), recorrendo ao TOTP (Time-Based One-Time Password). O sistema utiliza uma base de dados SQLite, armazena as passwords através de hash e mantém o segredo TOTP cifrado.

Nesta nova fase, o objetivo deixa de ser exclusivamente na segurança da autenticação e passa a dar maior importância à privacidade dos dados tratados durante o registo, a autenticação, a gestão da conta e o registo dos acessos. Com isto, pretendemos transformar o SecureAccess [1] numa aplicação orientada pelos princípios de *Privacy by Design* (PbD), minimização de dados, pseudonimização, retenção limitada, transparência e controlo de acesso.

II. Introdução

O SecureAccess Privacy será aplicado a uma empresa privada do setor tecnológico, que disponibiliza aos seus colaboradores um portal interno para autenticação e acesso a aplicações e informação empresarial. Este cenário permite utilizar o SecureAccess [1] como mecanismo central de autenticação e, simultaneamente, analisar de que forma devem ser protegidos os dados pessoais e de autenticação produzidos pelo sistema.

No contexto do SecureAccess Privacy, aplicado a uma empresa privada do setor tecnológico, o tratamento dos dados pessoais dos colaboradores poderá fundamentar-se no interesse legítimo da organização (artigo 6.º, n.º 1, alínea f), do RGPD), nomeadamente para garantir a segurança dos sistemas, gerir contas e controlar acessos, desde que respeitados os direitos dos colaboradores e demonstrada a necessidade do tratamento. Os dados de identificação, autenticação e auditoria devem limitar-se ao estritamente necessário. Os dados adicionais do perfil, como data de nascimento, género, NIF, morada, estado civil e fotografia, são facultativos no protótipo e utilizados com dados fictícios. Numa implementação real, a sua recolha exigiria uma finalidade específica e justificação da respetiva necessidade, em conformidade com os artigos 5.º e 6.º do RGPD.

O projeto enquadra-se nas áreas das Tecnologias de Informação, Segurança da Informação e Privacidade de Dados, incidindo especificamente sobre a gestão de identidades e acessos (IAM), que abrange a gestão de identidades, a autenticação, a autorização e o controlo de acesso.

O âmbito da privacidade considerado neste projeto inclui os processos de registo, autenticação multifator, gestão de contas e sessões, bem como o histórico de autenticação, incluindo os dados associados a esses processos. O conteúdo das aplicações e dos recursos empresariais acedidos após a autenticação não está incluído neste contexto.

Neste contexto, intervêm três elementos principais, o colaborador, que pode autenticar-se, consultar os seus dados e histórico de acessos, exportar os dados associados à sua conta e solicitar a sua eliminação. O administrador de segurança, responsável pela gestão das contas e pela consulta dos eventos técnicos estritamente necessários. E o próprio SecureAccess Privacy, que aplica as regras de autenticação, privacidade, retenção, pseudonimização e controlo de acessos.

A proteção dos dados assenta no princípio do menor privilégio, segundo o qual cada perfil deve ter acesso apenas à informação necessária para desempenhar as suas funções.

No âmbito deste projeto, são considerados privados todos os dados que permitam identificar um utilizador, autenticá-lo, descrever o seu comportamento de acesso ou comprometer a segurança da sua conta. Estas informações encontram-se distribuídas por diferentes categorias, apresentadas na Tabela I.

Ser considerado privado não significa necessariamente que o dado será armazenado pelo sistema. A classificação como privado refere-se à necessidade de proteger a informação devido à sua relação com o utilizador, a sua autenticação, o seu comportamento de acesso ou a segurança da sua conta.

Tabela I
CATEGORIAS DE DADOS PRIVADOS

Categoria	Exemplos	Justificação
Dados de identificação	Username e identificador interno do utilizador.	Permitem identificar ou distinguir um colaborador dentro da organização e associar-lhe os restantes dados da conta.
Dados do perfil pessoal	Nome completo, data de nascimento, género, NIF, morada, estado civil e fotografia.	Informações pessoais que permitem identificar ou caracterizar o utilizador e exigem proteção adequada à sua finalidade.
Dados organizacionais	Cargo profissional e departamento associado.	Informação sobre a função do colaborador na organização, que pode contribuir para a sua identificação.
Dados de autenticação	Hash da password, segredo TOTP cifrado e estado da MFA.	Estão diretamente relacionados com a autenticação e proteção da conta. O seu acesso indevido pode comprometer a segurança do utilizador.
Dados de sessão	Identificador de sessão e informação técnica necessária para manter a sessão autenticada.	Permitem associar uma determinada sessão a um utilizador autenticado e, se expostos, podem representar um risco para a segurança da sessão.
Histórico de autenticação	Data/hora, login com sucesso ou falha, falha de MFA, logout e outros eventos técnicos.	Permite conhecer o comportamento de autenticação do utilizador, incluindo quando e como tentou aceder ao sistema.
Comunicações de autenticação	Pedidos de login, submissão do TOTP e comunicação entre browser e servidor.	Podem conter ou estar associados a informação utilizada durante o processo de autenticação, permitindo relacionar uma determinada interação com o utilizador.
Dados do dispositivo	Apenas se futuramente forem necessários para autenticação adaptativa e sempre de forma limitada.	Podem permitir caracterizar ou associar um dispositivo a determinado utilizador e, dependendo da informação recolhida, contribuir para o rastreamento dos seus acessos.

Para cumprir o princípio da minimização, o sistema não deve guardar a palavra-passe original, os códigos TOTP utilizados, o segredo TOTP em texto simples ou o código QR de configuração. Sempre que sejam necessários dados de autenticação, estes devem ser tratados de forma adequada à sua sensibilidade.

O SecureAccess [1] já disponibiliza funcionalidades de registo e início de sessão, armazenamento da palavra-passe sob a forma de hash, autenticação multifator através de TOTP, cifragem do segredo TOTP, sessão de utilizador e dashboard após autenticação. O SecureAccess Privacy parte desta base e alarga o projeto à gestão da privacidade, acrescentando funcionalidades destinadas a reforçar a transparência e o controlo dos dados pessoais, conforme sumarizado na Tabela II.

Desta forma, o SecureAccess Privacy pretende complementar as funcionalidades de autenticação existentes com mecanismos de transparência, controlo e proteção dos dados pessoais. A evolução do sistema centra-se na redução dos dados armazenados ao estritamente necessário, na definição de regras de conservação e no reforço dos direitos dos utilizadores sobre os dados associados às suas contas.

III. ESTADO DA ARTE E TRABALHOS RELACIONADOS

A. *Privacy by Design e enquadramento regulamentar*

A abordagem *Privacy by Design* defende que a privacidade deve ser considerada desde o início do desenvolvimento de um sistema e ao longo do ciclo de vida dos dados. Esta abordagem possui sete princípios basilares, conforme observável na Figura 1, sendo estes a proatividade e prevenção, a privacidade por defeito, a privacidade integrada na conceção, a funcionalidade integral, a segurança ao longo de todo o ciclo de vida dos dados, a visibilidade e transparência e por último, o respeito pela privacidade do utilizador [2], [3].



Figura 1. Os sete princípios de Privacy by Design.

Para o SecureAccess Privacy, pretendemos usar estes princípios como orientação para a componente prática do projeto. A proatividade e prevenção vai orientar a identificação de riscos antes de qualquer implementação de novas funcionalidades, a privacidade por defeito e a integração da privacidade desde a conceção resulta na minimização de dados recolhidos e à restrição de acesso à informação pessoal. A segurança ao longo do ciclo de vida vai influenciar a definição de prazos de retenção para os logs, a transparência e respeito pela privacidade do utilizador traduz-se na página "Os meus dados" onde o utilizador poderá consultar a informação guardada, bem como à implementação de mecanismos de exportação e eliminação de dados.

A revisão sistemática de Andrade et al. (2022) mostra que ainda existe uma diferença entre os princípios de PbD e a sua aplicação prática na engenharia de software, nomeadamente ao nível dos métodos, modelos e ferramentas disponíveis [2].

Tabela II
COMPARAÇÃO ENTRE O SECUREACCESS E O SECUREACCESS PRIVACY

Componente	Situação atual	Atualização proposta
Registo e login	Já existe	Mantém-se como base do projeto.
Password em hash	Já existe	Mantém-se; a password original nunca será armazenada.
MFA/TOTP	Já existe	Mantém-se; o foco passa a incluir a privacidade dos dados MFA.
Segredo TOTP cifrado	Já existe	Mantém-se e será tratado como dado privado crítico.
Logs de autenticação	Não é funcionalidade principal atual	Criar logs mínimos e pseudonimizados.
Página "Os meus dados"	Não existe	Criar área de transparência para o utilizador.
Exportação de dados	Não existe	Permitir obter uma cópia dos dados associados à conta.
Eliminação de conta/dados	Não existe	Criar mecanismo de eliminação ou anonimização conforme as regras definidas.
Política de retenção	Não existe formalmente	Definir prazos e eliminar/anonimizar dados expirados.
Controlo de acesso admin	Básico	Aplicar perfis e princípio do menor privilégio.

Este resultado reforça a importância de traduzir os princípios em requisitos e funcionalidades concretos, cuja implementação possa ser verificada no SecureAccess Privacy.

O Regulamento Geral sobre a Proteção de Dados (RGPD) estabelece princípios como a minimização dos dados e a limitação da sua conservação, no artigo 5.º, n.º 1, alíneas (c) e (e). O artigo 25.º aborda a proteção de dados desde a conceção e por defeito [4]. O NIST Privacy Framework também apresenta orientações para a identificação e gestão dos riscos de privacidade [5].

No âmbito do projeto, estes referenciais servem de base para definir medidas como a recolha apenas dos dados necessários, a limitação do tempo de conservação dos registos, a transparência sobre os dados guardados e o controlo do acesso à informação pessoal.

B. Privacidade em sistemas de autenticação

A Open Worldwide Application Security Project (OWASP) destaca a importância dos registos de aplicação para acompanhar eventos de segurança e investigar incidentes. De acordo com a Logging Cheat Sheet, os registos devem conter informação suficiente para responder às questões quando, onde, quem e o quê. No entanto, não devem expor passwords, tokens, segredos criptográficos ou identificadores de sessão em bruto. Quando não é necessário identificar diretamente o utilizador, podem aplicar-se técnicas como a remoção, o mascaramento, o hashing ou a pseudonimização dos identificadores [6].

Estas recomendações são relevantes para o SecureAccess Privacy. Os registos de autenticação devem guardar apenas a informação necessária, como a data e hora, o tipo de evento, o resultado da autenticação e um identificador pseudonimizado do utilizador. O sistema não deve guardar passwords, códigos TOTP utilizados ou segredos TOTP em texto simples. Também deve existir um prazo de conservação dos registos, justificado pela sua finalidade e pelas necessidades de segurança. O RGPD não estabelece um prazo universal de conservação para todos os registos de autenticação.

C. Soluções de gestão de identidades e acessos existentes

A revisão sistemática de Glöckler et al. (2024) analisa os requisitos dos sistemas de gestão de identidades e acessos (Identity and Access Management, IAM) em contexto empresarial. Com base na análise da literatura e em entrevistas com especialistas, os autores organizam estes requisitos em quatro áreas: segurança e conformidade, funcionamento, tecnologia e utilizador. A área do utilizador inclui aspetos como a privacidade, a confiança, o controlo dos dados e a simplicidade de utilização [7].

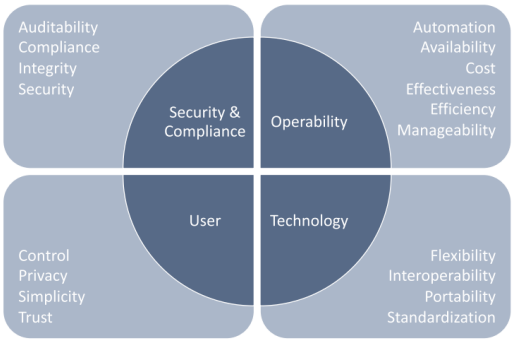


Figura 2. Requisitos para um sistema IAM empresarial. Retirado de https://doi.org/10.1007/s12599-023-00830-x

O artigo também aborda a autenticação multifator como uma forma de reforçar a segurança e destaca o princípio do menor privilégio, segundo o qual os utilizadores devem possuir apenas as permissões necessárias às suas funções.

O Okta e o Keycloak podem servir como referências para analisar funcionalidades de plataformas IAM existentes. A comparação limita-se às funcionalidades relevantes para o projeto e às informações que a documentação oficial permite confirmar (Tabela III).

Esta comparação evidencia que quer o Okta quer o Keycloak disponibilizam mecanismos de autenticação multifator (MFA), registo de eventos e gestão de permissões administrativas. Estas necessidades servirão de referência para a evolução do

Tabela III
COMPARAÇÃO ENTRE OKTA, KEYCLOAK E SECUREACCESS PRIVACY

Critério	Okta	Keycloak	SecureAccess Privacy
MFA	Suporta vários tipos de autenticadores e políticas [8].	Suporta passkey, recovery codes e TOTP/HOTP [9].	Já possui password e TOTP. Pretende-se manter e proteger.
Registos	System Log regista eventos, tabela com exportação CSV, gráficos [10].	Eventos customizáveis (Login, Brute force, etc.) [9].	Registos mínimos, pseudonimizados com data/hora e resultado.
Retenção	Janela de 90 dias [11].	Configurável com opções de expiração [9].	Fazer prazo próprio e eliminação automática.
Consulta dados	Gestão de perfis (não 100% área dedicada de privacidade).	Account Console gere perfil e atividade, não é exportação total [9].	Página "Os meus dados" dedicada.
Exportação	Exporta System Log (CSV) [10].	Não documentada claramente para utilizadores finais.	Exportação segura de dados, sem credenciais.
Eliminação	Eliminação por admins [12].	Via Account Console (se ativada) [9].	Mecanismo seguro de eliminação pelo utilizador e políticas claras.
Acesso Admin	Diferenciadas por recursos [13], [14].	Permissões granulares de gestão [9].	Perfis separados e princípio do menor privilégio.
Infraestrutura	Serviço Cloud.	Solução open source local.	Protótipo Flask + SQLite sob controlo.

protótipo, sem pressupor que as soluções analisadas não permitem obter resultados semelhantes através de configurações ou extensões.

IV. CRITÉRIOS E REQUISITOS DE PRIVACIDADE

De maneira a possuir uma política de segurança concordante com o Regulamento Geral sobre a Proteção de Dados (RGPD), no que diz respeito ao artigo 5.º, n.º 1, alíneas (c) e (e), o SecureAccess Privacy compromete-se a:

- Recolher apenas a informação necessária para a autenticação e segurança.
- Usar identificadores técnicos nos logs em vez de expor diretamente o username sempre que possível.
- Aplicar um período de conservação de 90 dias aos logs de auditoria, com eliminação dos registos expirados através de um processo de limpeza.

Para com os utilizadores e considerando os seus direitos de privacidade:

- Permitir consultar que dados o sistema guarda (área "Os meus dados").
- Permitir gerar uma cópia dos dados associados à conta.
- Permitir apagar a conta, terminando assim o processamento dos mesmos.
- Limitar o acesso administrativo aos dados.
- Proteger dados de autenticação em armazenamento e comunicação.

A Diretiva NIS2 constitui uma referência adicional para a gestão e comunicação de incidentes de cibersegurança.

O artigo 23.º estabelece, para as entidades abrangidas, obrigações de notificação de incidentes significativos.

Entre estas obrigações encontram-se um alerta precoce, no prazo máximo de 24 horas após o conhecimento do incidente, e uma notificação mais detalhada no prazo de 72 horas.

A diretiva prevê ainda a apresentação de um relatório final, em regra, até um mês após a notificação do incidente.

No SecureAccess Privacy, estes procedimentos são considerados como referência para uma possível evolução, não tendo sido implementado um sistema automático de notificação às autoridades competentes [15].

V. ESTRUTURA DA BASE DE DADOS (ATRIBUTOS)

A. Requisitos funcionais da base de dados

A evolução da estrutura da base de dados permitiu suportar a gestão de contas, credenciais, perfis de acesso, dados pessoais, departamentos, cargos profissionais, eventos de auditoria, pedidos de eliminação e políticas de conservação.

B. Enquadramento regulamentar

A evolução da base de dados teve como referência os artigos 5.º e 25.º do RGPD, nomeadamente os princípios de minimização dos dados, limitação da conservação e proteção de dados desde a conceção e por defeito.

C. Análise da base de dados original

A versão original do SecureAccess utilizava SQLite e uma estrutura centrada na tabela `users`, apresentada na Tabela IV.

Tabela IV
ESTRUTURA ORIGINAL DA TABELA `USERS`

Atributos	Descrição
`id`	identificador único de cada utilizador
`username`	nome de utilizador (único e obrigatório)
`password_hash`	hash da palavra-passe
`totp_secret`	segredo utilizado na MFA (TOTP), cifrado
`mfa_enabled`	identificador se a MFA está ativada
`created_at`	data e hora de criação da conta

Esta estrutura permite armazenar a informação essencial para a gestão das contas e para os mecanismos de autenticação previstos no projeto. A utilização de um identificador único, a restrição de unicidade do nome de utilizador e o armazenamento de hashes das palavras-passe contribuem para a organização e proteção dos dados. Contudo, apresenta algumas limitações face aos requisitos de privacidade definidos para

o projeto. A tabela não inclui um atributo para distinguir os perfis de utilizador e administrador, nem contempla uma estrutura própria para registar o histórico de eventos e permissões de cada utilizador. Também não dispõe de mecanismos específicos, ao nível da estrutura de dados, para apoiar a consulta e exportação dos dados pessoais, a gestão dos pedidos de eliminação de contas ou o controlo dos prazos de conservação da informação. Assim, embora a estrutura existente seja suficiente para suportar os dados básicos das contas e da autenticação, deverá ser complementada para responder de forma mais abrangente aos requisitos de controlo de acesso, transparência e gestão do ciclo de vida dos dados.

D. Evolução implementada e justificação

A evolução do SecureAccess Privacy permitiu alargar a estrutura original da base de dados SQLite, de modo a suportar a gestão de contas, a proteção dos dados pessoais, os mecanismos de auditoria e o controlo do ciclo de vida da informação.

A implementação final utiliza SQLAlchemy como camada de acesso aos dados e Flask-Migrate/Alembic para a gestão das alterações ao esquema, com preservação das contas existentes durante as migrações.

Na tabela `users`, foram acrescentados atributos para identificar o perfil de acesso (`role`), o estado da conta (`active`) e o controlo das sessões (`session_version`). O atributo `last_totp_step` permite impedir a reutilização de códigos TOTP no mesmo intervalo temporal.

O controlo de acesso foi implementado através de dois perfis, `user` e `admin`, com verificação das permissões no backend. Ao contrário da proposta conceptual inicial, não foram criadas tabelas independentes `permissions` e `user_permissions`, uma vez que o modelo adotado utiliza permissões associadas aos perfis da aplicação.

Foi criada a entidade `user_profiles`, associada à conta numa relação de um para um, para separar os dados pessoais adicionais dos atributos necessários à autenticação. Esta entidade permite armazenar, de forma facultativa, nome completo, data de nascimento, género, NIF, morada, estado civil e fotografia.

A gestão dos dados organizacionais foi alargada através das entidades `departments` e `job_positions`. A primeira representa os departamentos da organização, enquanto a segunda identifica os cargos associados a cada departamento.

A ligação entre o perfil do colaborador e o cargo é estabelecida através do atributo `job_position_id`, uma chave estrangeira facultativa que referencia `job_positions`. O atributo textual `job_title` foi mantido por motivos de compatibilidade com informação anterior, mas as novas atribuições de cargos utilizam a referência à entidade correspondente.

Foram igualmente acrescentadas as entidades `audit_logs`, `deletion_requests`, `deletion_history` e `auth_attempts`, destinadas à auditoria pseudonimizada, aos pedidos de eliminação, ao histórico dos respetivos estados e à limitação das tentativas de autenticação.

Desta forma, a base de dados implementada corresponde às necessidades funcionais efetivamente desenvolvidas, mantendo a separação entre credenciais, dados pessoais facultativos, eventos de segurança e operações relativas à privacidade.

VI. Modelo conceptual e entidades

A. Entidades do modelo implementado

O modelo de dados da versão atual é constituído por oito entidades principais:

- **USERS:** armazena os identificadores da conta, credenciais, configuração MFA, perfil de acesso e informação de controlo das sessões.
- **USER_PROFILES:** reúne os dados pessoais facultativos do utilizador, incluindo nome completo, data de nascimento, género, NIF, morada, estado civil, fotografia e associação ao cargo organizacional.
- **DEPARTMENTS:** representa os departamentos da organização, incluindo nome, descrição, estado de atividade e datas de criação e atualização.
- **JOB_POSITIONS:** representa os cargos profissionais, associados a um departamento, com identificação, descrição e estado de atividade.
- **AUDIT_LOGS:** conserva eventos de segurança e privacidade através de referências pseudonimizadas.
- **DELETION_REQUESTS:** regista os pedidos de eliminação da conta e o respetivo estado.
- **DELETION_HISTORY:** conserva as transições de estado dos pedidos de eliminação.
- **AUTH_ATTEMPTS:** mantém contadores temporários para limitar tentativas de autenticação.

A entidade `users` possui uma relação de um para zero ou um com `user_profiles`, uma vez que a conta pode existir sem um perfil pessoal preenchido.

Cada perfil pessoal pertence obrigatoriamente a uma conta e pode estar associado a zero ou um cargo profissional, através de `job_position_id`.

Cada departamento pode possuir vários cargos, enquanto cada cargo pertence obrigatoriamente a um único departamento.

Um cargo pode estar associado a vários perfis pessoais, sem que esta associação determine automaticamente as permissões de acesso à aplicação.

Esta estrutura permite centralizar a informação organizacional e evita a repetição dos nomes dos departamentos e cargos nos perfis individuais.

A entidade `users` pode estar associada a vários pedidos de eliminação.

A referência `deletion_requests.user_id` é facultativa e utiliza a ação `ON DELETE SET NULL`, permitindo que um pedido concluído permaneça temporariamente registado sem ligação direta à conta eliminada.

Cada pedido pode possuir vários registos de histórico, associados através de uma chave estrangeira com `ON DELETE CASCADE`.

Os registos de audit_logs não possuem uma chave estrangeira direta para users, uma vez que utilizam referências pseudonimizadas calculadas com HMAC-SHA256.

A entidade auth_attempts permanece independente, com identificadores técnicos pseudonimizados para o controlo das tentativas de autenticação.

B. Diagrama de classes UML

A Figura 3 apresenta o modelo de dados atualizado do SecureAccess Privacy, constituído por oito entidades.

O diagrama inclui a estrutura organizacional introduzida através de departments e job_positions, bem como a associação destas entidades aos perfis pessoais.

O diagrama representa as associações estabelecidas por chaves estrangeiras. As tabelas audit_logs e auth_attempts não possuem uma relação referencial direta com users, pois utilizam identificadores técnicos pseudonimizados.

VII. Modelo lógico e dicionário de dados

O modelo lógico atualizado utiliza SQLite e SQLAlchemy, com oito tabelas responsáveis pela gestão das contas, perfis pessoais, estrutura organizacional, eventos de auditoria, pedidos de eliminação e controlo das tentativas de autenticação.

A Tabela V apresenta os principais atributos e respetivos tipos de dados das entidades implementadas.

A. Restrições de integridade

O atributo username é obrigatório e único. O email também possui restrição de unicidade, com comparação insensível a maiúsculas e minúsculas. O perfil de acesso está limitado aos valores user e admin, enquanto o estado da conta é representado pelo atributo active, com valores 0 ou 1.

A tabela user_profiles utiliza user_id como chave primária e estrangeira, garantindo a associação de cada perfil pessoal a uma única conta.

Os pedidos de eliminação encontram-se associados ao utilizador através de user_id, com possibilidade de remover essa associação após a conclusão do pedido. O histórico das transições é associado ao pedido através de request_id.

Os registos de auditoria utilizam identificadores pseudonimizados, sem dependência de uma chave estrangeira direta para a tabela de utilizadores.

A idade apresentada na interface é calculada a partir de birth_date. O atributo legacy_age destina-se apenas à preservação de informação proveniente de uma migração anterior.

A entidade departments possui uma restrição de unicidade sobre o nome do departamento, com comparação insensível a maiúsculas e minúsculas.

Na entidade job_positions, a combinação dos atributos department_id e name deve ser única. Esta restrição impede a duplicação do mesmo cargo dentro de um departamento, sem impedir que diferentes departamentos possuam cargos com nomes iguais.

O atributo department_id constitui uma chave estrangeira obrigatória para departments, com restrição ON DELETE RESTRICT.

Em user_profiles, o atributo job_position_id é uma chave estrangeira facultativa para job_positions, também com ON DELETE RESTRICT.

Estas restrições impedem a eliminação de departamentos com cargos associados e de cargos que permaneçam atribuídos a perfis pessoais.

Os departamentos e cargos possuem ainda o atributo is_active, que permite distinguir os registos ativos dos inativos, sem exigir a sua eliminação imediata.

A entidade audit_logs inclui uma restrição CHECK que limita o atributo result aos valores sucesso e falha.

Na entidade deletion_requests, o atributo status está limitado aos valores pendente, em processamento e concluído.

Uma restrição adicional garante que completed_at apenas contém uma data quando o pedido se encontra no estado concluído.

Foi também definido um índice único parcial sobre user_id, que impede a existência de mais do que um pedido de eliminação não concluído para o mesmo utilizador.

VIII. Ciclo de vida dos dados

A política de conservação implementada distingue os dados necessários à existência da conta, os registos de auditoria, os comprovativos de eliminação e os contadores técnicos temporários.

A. Aplicação da política de retenção

A aplicação inclui um serviço de limpeza responsável pela identificação e eliminação de registos que ultrapassem os prazos definidos.

A limpeza é executada durante o processamento de pedidos HTTP não estáticos, podendo também ser iniciada através de um comando administrativo na consola.

Os logs associados a uma conta são eliminados antecipadamente quando o respetivo pedido de eliminação é concluído.

A conclusão de um pedido remove a conta, as respetivas credenciais, o perfil pessoal, os eventos de auditoria associados e os contadores de autenticação ligados à identidade.

O comprovativo de eliminação deixa de manter uma referência direta ao utilizador e é conservado temporariamente, de acordo com a política definida.

O prazo de 90 dias constitui uma decisão de implementação do protótipo académico, não correspondendo a um prazo universal imposto pelo RGPD.

Tabela V
DICIONÁRIO DE DADOS DO MODELO IMPLEMENTADO

Entidade	Atributos e tipos	Finalidade
users	id (INTEGER, PK) username (TEXT) email (VARCHAR(254)) password_hash (TEXT) totp_secret (TEXT) mfa_enabled (INTEGER) created_at (TEXT) role (TEXT) active (INTEGER) session_version (INTEGER) last_totp_step (INTEGER)	Gestão de contas, credenciais, autenticação multifator, perfis de acesso e sessões.
user_profiles	user_id (INTEGER, PK/FK) full_name (VARCHAR(120)) birth_date (DATE) legacy_age (INTEGER) gender (VARCHAR(40)) tax_number (VARCHAR(9)) address (VARCHAR(300)) marital_status (VARCHAR(30)) job_title (VARCHAR(120), legado) job_position_id (INTEGER, FK) photo (BLOB) updated_at (TEXT)	Armazenamento de dados pessoais facultativos e da fotografia do utilizador.
audit_logs	id (INTEGER, PK) user_ref (TEXT) event_type (TEXT) event_timestamp (TEXT) result (TEXT)	Registo mínimo de eventos de autenticação, segurança e privacidade.
deletion_requests	id (INTEGER, PK) user_id (INTEGER, FK) requested_at (TEXT) status (TEXT) completed_at (TEXT)	Gestão e acompanhamento dos pedidos de eliminação de contas.
deletion_history	id (INTEGER, PK) request_id (INTEGER, FK) status (TEXT) changed_at (TEXT)	Histórico das alterações de estado dos pedidos de eliminação.
auth_attempts	bucket (TEXT, PK) attempts (INTEGER) expires_at (INTEGER)	Controlo temporário de tentativas de autenticação.
departments	id (INTEGER, PK) name (VARCHAR(120), UNIQUE) description (VARCHAR(1000)) is_active (BOOLEAN) created_at (TEXT) updated_at (TEXT)	Identificação e gestão dos departamentos da organização.
job_positions	id (INTEGER, PK) department_id (INTEGER, FK) name (VARCHAR(120)) description (VARCHAR(1000)) is_active (BOOLEAN) created_at (TEXT) updated_at (TEXT)	Gestão dos cargos associados aos departamentos e atribuição de funções aos colaboradores.

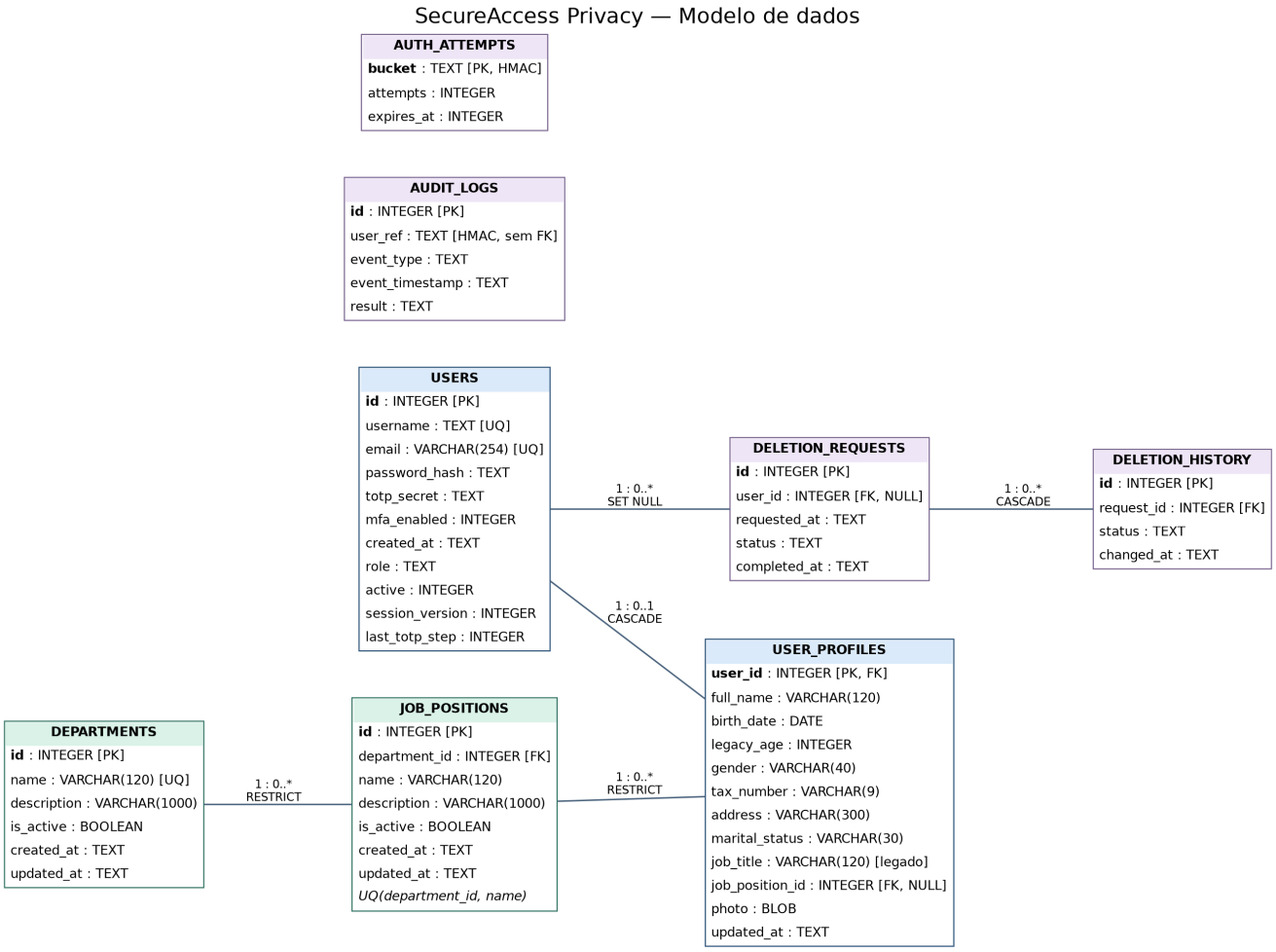


Figura 3. Diagrama UML atualizado do modelo de dados do SecureAccess Privacy.

Tabela VI
POLÍTICA DE CONSERVAÇÃO IMPLEMENTADA

Categoria	Prazo	Tratamento
Conta e credenciais	Até à eliminação da conta	Eliminação dos dados associados à conta.
Perfil pessoal	Enquanto necessário à conta	Eliminação em conjunto com a conta.
Logs de auditoria	90 dias	Remoção dos registos expirados.
Pedidos pendentes	Até ao tratamento	Conservação até à conclusão do pedido.
Comprovativos concluídos	90 dias após conclusão	Eliminação após expiração do prazo.
Contadores técnicos	15 minutos	Remoção após expiração da janela.
Departamentos e cargos	Enquanto necessários	Conservação enquanto forem relevantes para a organização, com possibilidade de desativação e eliminação sujeita às restrições de integridade.

IX. Modelagem de novos ecrãs

A. User View

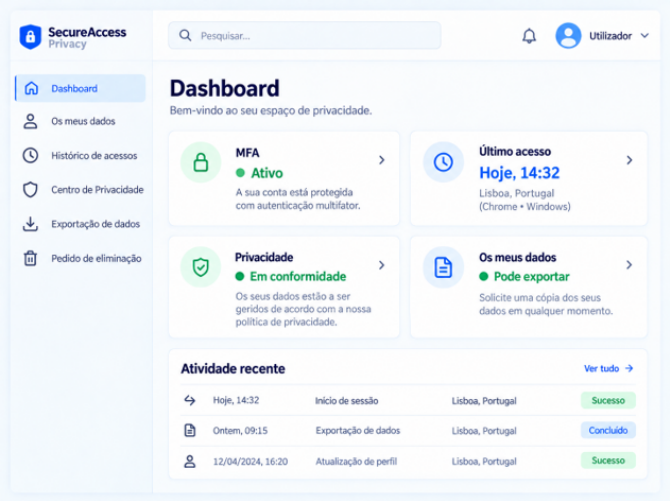


Figura 4. Dashboard principal do utilizador.

A Figura 4 apresenta o painel principal do utilizador após a autenticação no SecureAccess Privacy. Este ecrã disponibiliza uma visão geral do estado de segurança da conta, incluindo a ativação da autenticação multifator (MFA), o último acesso realizado e informações relativas à privacidade dos dados. Adicionalmente, apresenta um resumo das atividades recentes, permitindo ao utilizador acompanhar os principais eventos associados à sua conta.

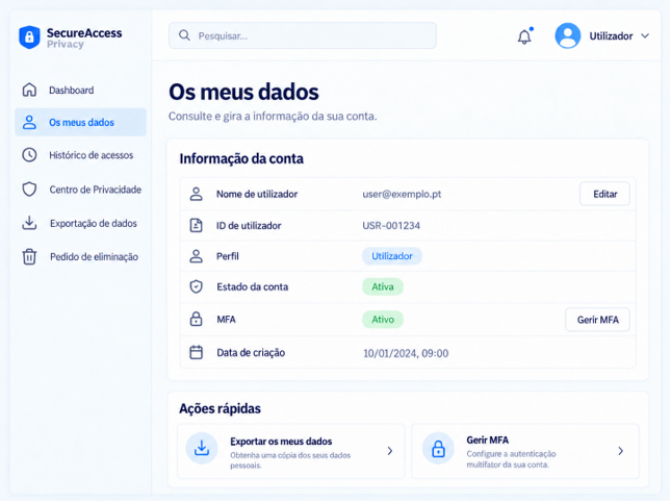


Figura 5. Consulta e gestão dos dados pessoais.

A Figura 5 representa a página "Os meus dados", onde o utilizador pode consultar as informações associadas à sua conta, nomeadamente o identificador, o nome de utilizador, o perfil de acesso, o estado da conta, a configuração da autenticação multifator e a data de criação. Este ecrã pretende promover a transparência no tratamento dos dados pessoais e facilitar o acesso à informação armazenada pelo sistema, sem expor credenciais ou segredos de autenticação.

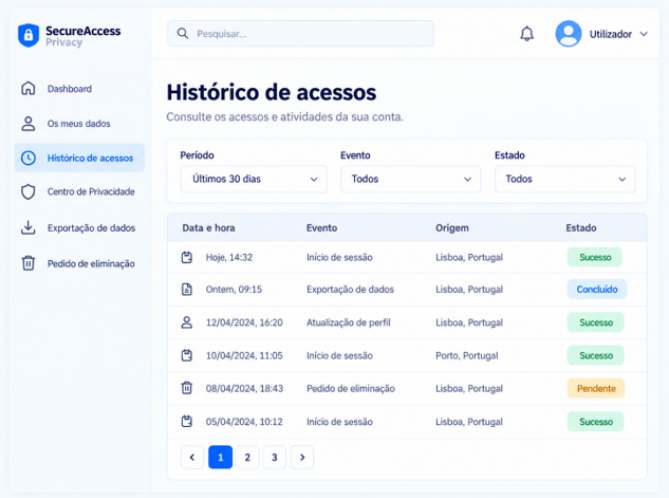


Figura 6. Histórico de acessos e atividades do utilizador.

A Figura 6 apresenta o histórico de eventos relacionados com a autenticação e a atividade da conta. Através deste ecrã, o utilizador pode consultar a data e hora dos acontecimentos, o tipo de evento, a origem e o respetivo resultado. São igualmente disponibilizados filtros que facilitam a pesquisa de registos, contribuindo para uma maior transparência e permitindo identificar possíveis tentativas de acesso não autorizadas.

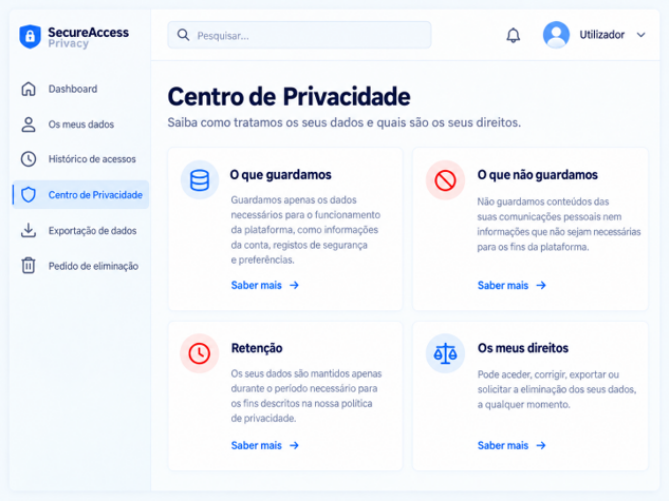


Figura 7. Centro de Privacidade e transparência dos dados.

A Figura 7 representa o Centro de Privacidade, destinado a informar o utilizador sobre o tratamento dos seus dados pessoais. O ecrã apresenta informação organizada sobre os dados armazenados, os dados que não são conservados, os princípios de retenção e os direitos do utilizador. Esta

funcionalidade procura concretizar os princípios de Privacy by Design, promovendo a transparência, a minimização dos dados e o conhecimento dos procedimentos de proteção da informação.

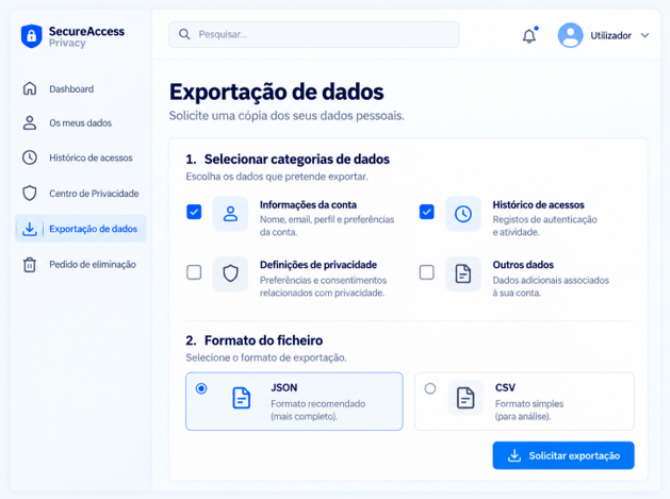


Figura 8. Exportação dos dados pessoais.

A Figura 8 apresenta a interface de exportação de dados, através da qual o utilizador pode solicitar uma cópia das informações associadas à sua conta. O ecrã permite selecionar as categorias de dados a incluir na exportação, como informações da conta e histórico de acessos, bem como escolher o formato do ficheiro, nomeadamente JSON ou CSV. Esta funcionalidade visa facilitar o exercício do direito de acesso aos dados, garantindo que informações sensíveis de autenticação não são incluídas na exportação.



Figura 9. Pedido de eliminação da conta e dos dados pessoais.

A Figura 9 apresenta a interface destinada à submissão de pedidos de eliminação da conta e dos respetivos dados pessoais. Antes da confirmação, o sistema informa o utilizador sobre as consequências da operação e sobre a possibilidade de determinados registos permanecerem armazenados quando exista fundamento para a sua conservação. O ecrã inclui ainda um mecanismo de confirmação e uma área de acompanhamento dos pedidos anteriormente submetidos, permitindo consultar o respetivo estado.

B. Admin View

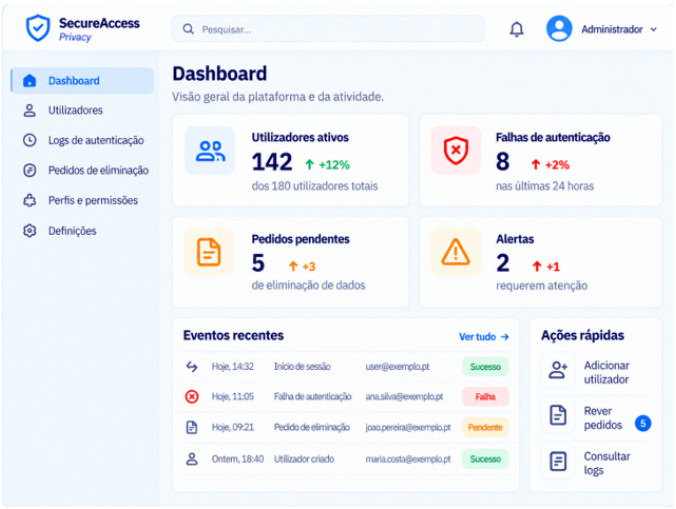


Figura 10. Dashboard de administração e monitorização de segurança.

A Figura 10 apresenta o painel principal do administrador, que disponibiliza uma visão geral da atividade do SecureAccess Privacy. Este ecrã reúne indicadores relativos ao número de utilizadores ativos, falhas de autenticação, pedidos de eliminação pendentes e alertas de segurança. Adicionalmente, apresenta os eventos mais recentes e permite aceder rapidamente às funcionalidades administrativas, facilitando a monitorização do sistema.

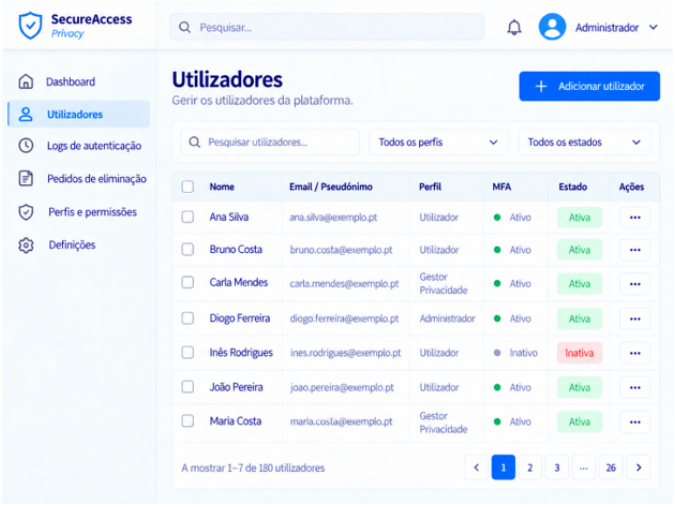


Figura 11. Gestão de utilizadores e contas.

A Figura 11 representa a interface de gestão de utilizadores, através da qual o administrador pode consultar as contas registadas no sistema. São apresentados os dados necessários à administração das contas, incluindo a identificação do utilizador, o perfil atribuído, o estado da autenticação multifator e o estado da conta. O ecrã disponibiliza ainda mecanismos de pesquisa e filtragem, bem como operações administrativas sujeitas às permissões do respetivo perfil.

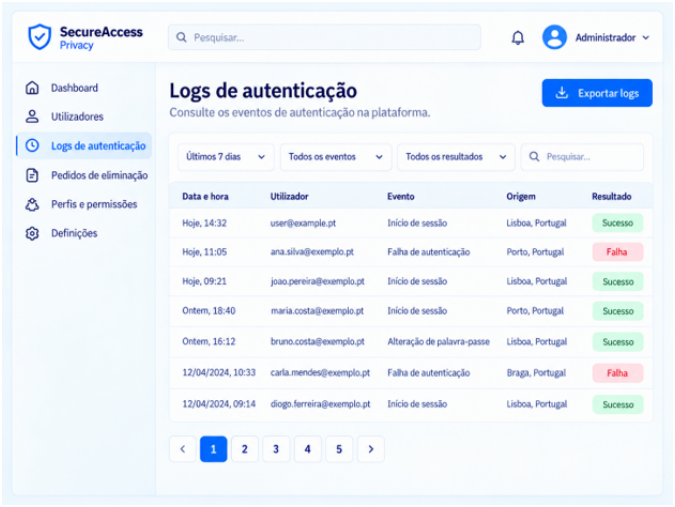


Figura 12. Consulta dos registos de autenticação e auditoria.

A Figura 12 apresenta a interface de consulta dos registos de autenticação, destinada à monitorização de eventos relevantes para a segurança do sistema. Os registos são organizados de acordo com a data e hora, a referência ao utilizador, o tipo de evento, a origem e o resultado da operação. No âmbito do SecureAccess Privacy, pretende-se que os identificadores apresentados nos registos sejam pseudonimizados sempre que possível, reduzindo a exposição de dados pessoais e respeitando o princípio do menor privilégio.

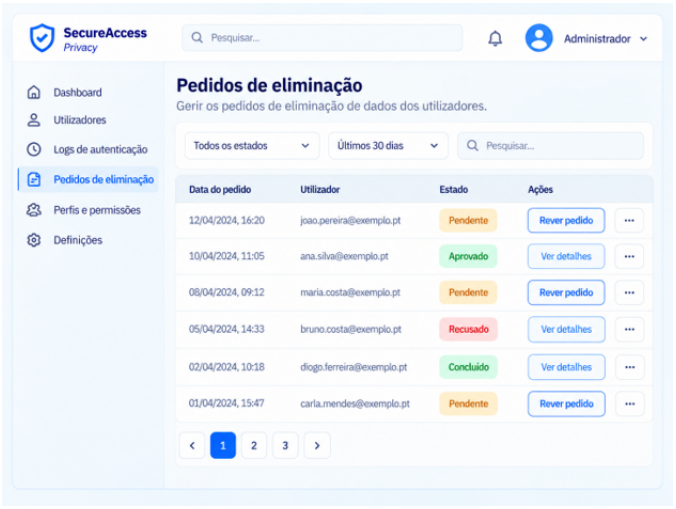


Figura 13. Gestão dos pedidos de eliminação de dados.

A Figura 13 representa o ecrã de administração dos pedidos de eliminação submetidos pelos utilizadores. Esta interface permite consultar a data de apresentação, a referência ao utilizador e o estado de cada pedido, incluindo situações pendentes, em processamento ou concluídas. O administrador poderá acompanhar o tratamento dos pedidos e realizar as operações autorizadas, respeitando as políticas de conservação dos dados e os procedimentos de eliminação definidos para o sistema.

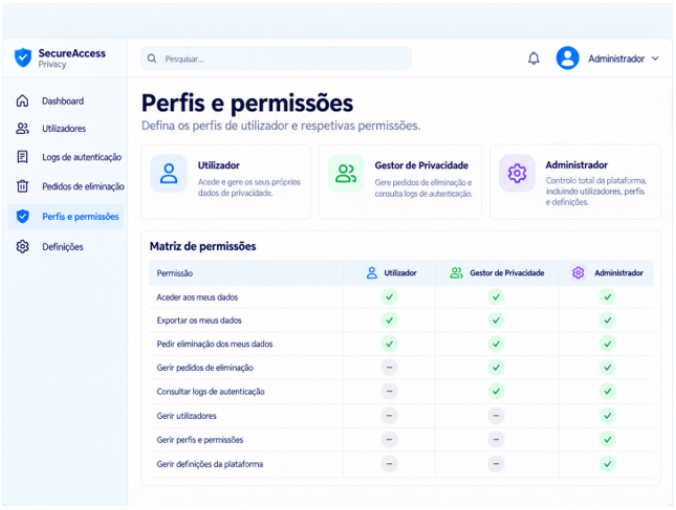


Figura 14. Gestão de perfis e permissões de acesso.

A Figura 14 apresenta a interface destinada à visualização e gestão dos perfis de acesso do SecureAccess Privacy. O ecrã inclui uma matriz de permissões que permite identificar as funcionalidades disponíveis para cada perfil, distinguindo as

operações acessíveis aos utilizadores comuns daquelas reservadas à administração. Esta abordagem procura demonstrar a aplicação do princípio do menor privilégio, garantindo que cada utilizador dispõe apenas das permissões necessárias ao desempenho das suas funções.

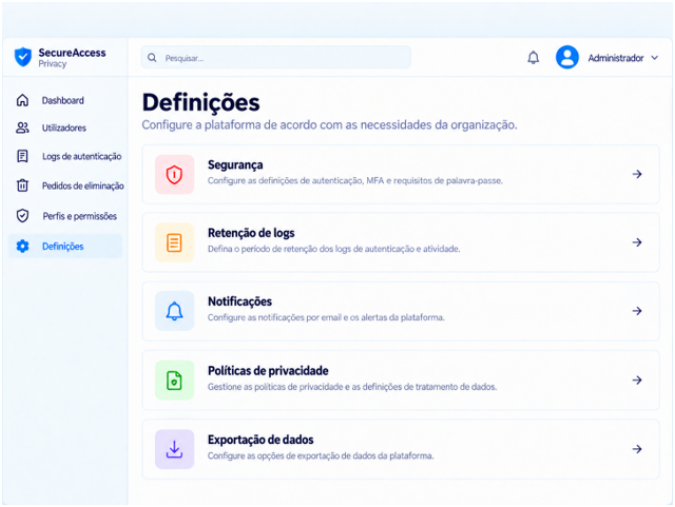


Figura 15. Configuração das políticas de segurança e privacidade.

A Figura 15 representa a interface de definições administrativas, que centraliza as opções de configuração relacionadas com a segurança e a privacidade do sistema. Entre as funcionalidades ilustradas encontram-se as políticas de autenticação, a gestão dos períodos de retenção dos registos, as notificações, as políticas de privacidade e as opções de exportação de dados. Este ecrã pretende demonstrar como as regras de proteção e conservação da informação poderão ser configuradas e aplicadas de forma consistente.

Os ecrãs apresentados nesta secção correspondem aos mockups definidos durante a fase de conceção. A secção seguinte apresenta a implementação efetivamente desenvolvida, permitindo comparar a proposta visual inicial com as funcionalidades disponibilizadas na aplicação final.

X. Implementação prática do SecureAccess Privacy

Após a definição dos requisitos funcionais, do modelo de dados e dos protótipos de interface, procedeu-se à implementação prática do SecureAccess Privacy.

O sistema foi desenvolvido em Python, com Flask como framework web, SQLAlchemy para o acesso à base de dados SQLite e Flask-Migrate/Alembic para a gestão das migrações.

A arquitetura foi organizada segundo um monólito modular, com separação entre rotas HTTP, serviços responsáveis pela lógica de negócio, modelos de dados, mecanismos de segurança, templates e recursos estáticos.

A aplicação mantém o processo de autenticação através de palavra-passe e TOTP, ao qual foram acrescentadas funcionalidades de gestão de dados pessoais, auditoria, controlo de acesso por perfis, exportação, eliminação e conservação limitada da informação.

Foram desenvolvidas interfaces distintas para os perfis de utilizador e administrador, com seis ecrãs principais para cada perfil, conforme os mockups anteriormente apresentados.

A. Autenticação e proteção das contas

O processo de registo permite criar uma conta através de um nome de utilizador, email e palavra-passe. A autenticação multifator é realizada através de códigos TOTP.

As palavras-passe são armazenadas sob a forma de hash, enquanto os segredos TOTP são cifrados com Fernet. Os códigos TOTP utilizados e os códigos QR de configuração não são conservados como registos persistentes.

Foram implementados mecanismos de limitação de tentativas de autenticação, proteção CSRF, verificação das permissões no backend e controlo da duração das sessões.

As operações de exportação e de alteração de dados pessoais exigem confirmação de identidade através da palavra-passe e de um código MFA válido.

B. Estrutura organizacional e cargos

A evolução da aplicação passou a contemplar uma estrutura organizacional composta por departamentos e cargos profissionais.

A entidade `departments` permite representar as diferentes unidades da organização, enquanto `job_positions` define os cargos associados a cada departamento.

A atribuição de um cargo a um colaborador é efetuada através de uma referência armazenada no respetivo perfil pessoal, permitindo associar vários colaboradores ao mesmo cargo.

A informação do cargo e do departamento pode ser obtida a partir dessa associação, sem necessidade de duplicar os respetivos nomes em cada perfil.

Por motivos de compatibilidade, o campo textual `job_title` continua presente no modelo, mas as novas atribuições utilizam `job_position_id`.

O sistema distingue o cargo profissional do perfil de acesso à aplicação. O cargo representa a função organizacional do colaborador, enquanto o perfil `user` ou `admin` determina as operações autorizadas.

Esta separação permite representar a estrutura da organização sem associar automaticamente privilégios administrativos a um determinado departamento ou cargo.

C. Interfaces implementadas do utilizador

A interface do utilizador foi desenvolvida para disponibilizar informação sobre a segurança da conta, facilitar o acesso aos dados pessoais e permitir o exercício das operações de privacidade previstas no projeto.

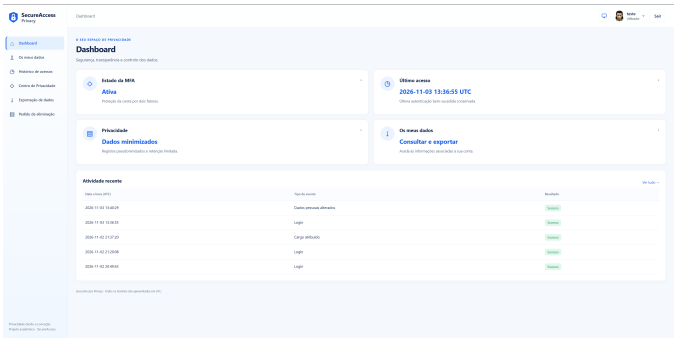


Figura 16. Dashboard do utilizador implementado.

A Figura 16 apresenta o *Dashboard* do utilizador, que disponibiliza o estado da MFA, o último acesso registado e indicadores relativos à privacidade e aos dados da conta.

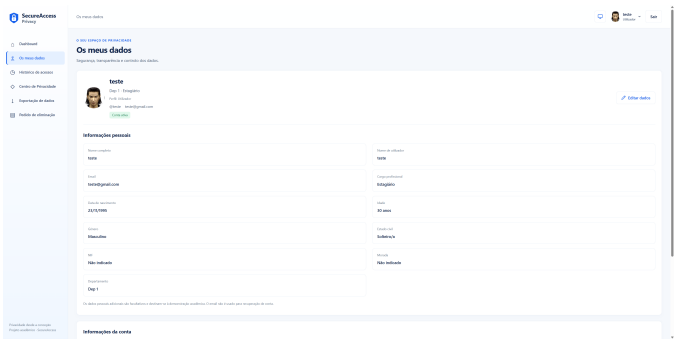


Figura 17. Página Os meus dados implementada.

A Figura 17 apresenta a página “Os meus dados”, que permite consultar os dados da conta e editar os atributos pessoais facultativos, como nome completo, data de nascimento, género, NIF, morada e estado civil.

A idade é calculada automaticamente a partir da data de nascimento. A interface permite ainda carregar, substituir ou remover uma fotografia de perfil.

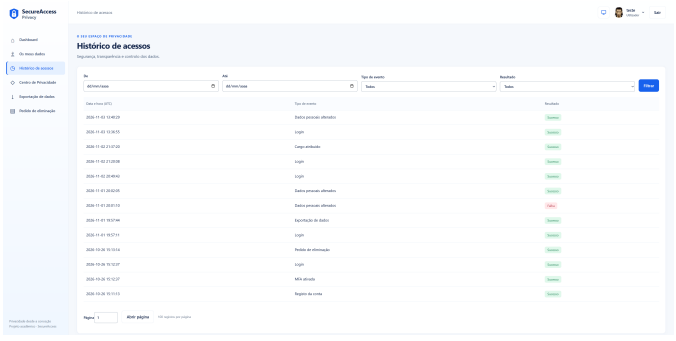


Figura 18. Histórico de acessos implementado.

A Figura 18 apresenta o “Histórico de acessos”, que disponibiliza os eventos associados à conta autenticada, com filtros por data, tipo de evento e resultado.

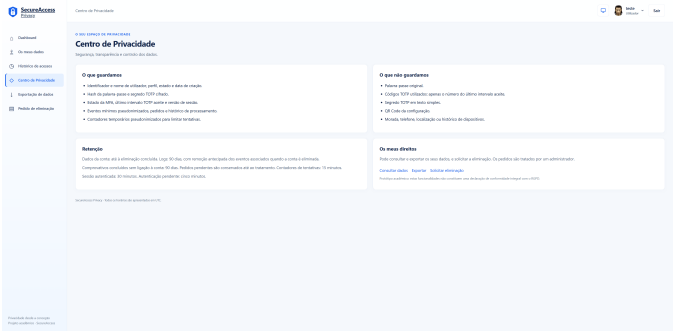


Figura 19. Centro de Privacidade implementado.

A Figura 19 apresenta o “Centro de Privacidade”, que disponibiliza informação sobre as categorias de dados tratados, os mecanismos de proteção, os prazos de conservação e as operações disponíveis ao utilizador.

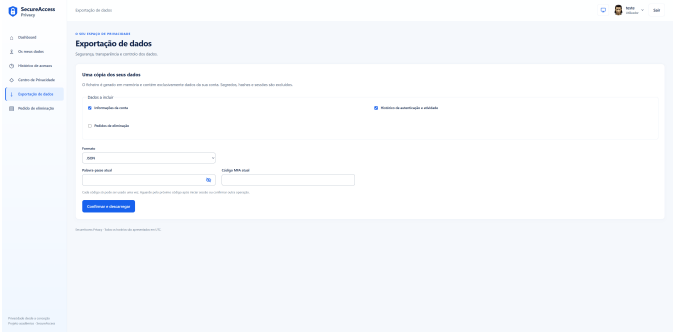


Figura 20. Interface de exportação de dados implementada.

A Figura 20 apresenta a interface de “Exportação de dados”, que permite selecionar informação da conta, histórico de atividade e pedidos de eliminação, com geração de ficheiros JSON ou CSV.

A exportação não inclui hashes de palavras-passe, segredos TOTP, chaves criptográficas ou tokens de sessão.

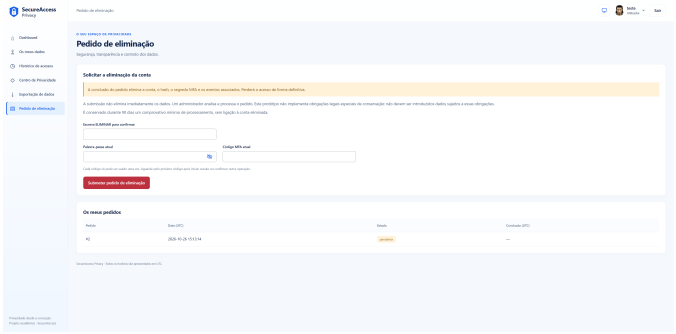


Figura 21. Interface de pedido de eliminação implementada.

A Figura 21 apresenta a interface “Pedido de eliminação”, que permite ao utilizador solicitar a eliminação da sua conta e acompanhar o estado do pedido.

O processamento do pedido fica sujeito ao fluxo de estados definido na aplicação e às operações autorizadas ao administrador.

D. Interfaces implementadas do administrador

A área administrativa disponibiliza funcionalidades de gestão e monitorização do sistema, com acesso restrito ao perfil `admin`.

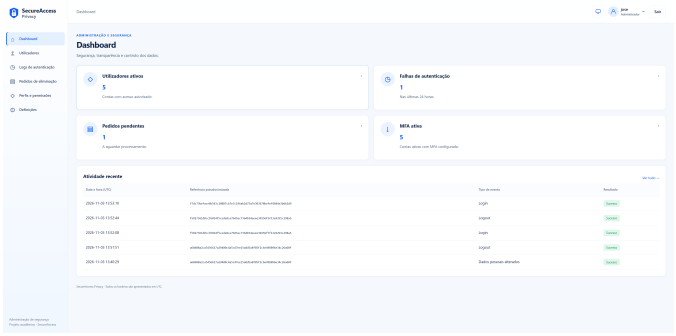


Figura 22. Dashboard administrativo implementado.

A Figura 22 apresenta o *Dashboard* administrativo, que disponibiliza indicadores relativos a utilizadores ativos, falhas de autenticação nas últimas 24 horas, pedidos de eliminação pendentes e contas com MFA ativa.

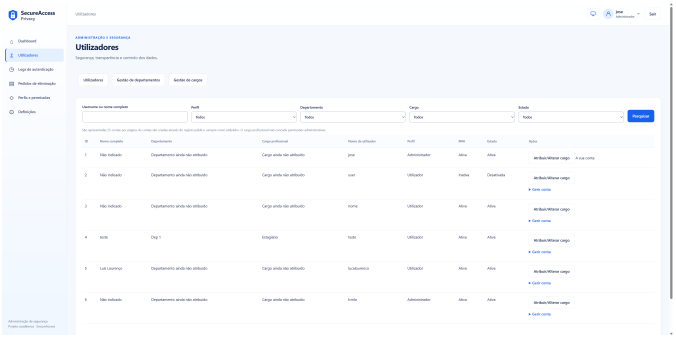


Figura 23. Gestão de utilizadores implementada.

A Figura 23 apresenta a página “Utilizadores”, que permite pesquisar contas, consultar o seu estado e executar operações autorizadas de ativação, desativação ou alteração do perfil de acesso.

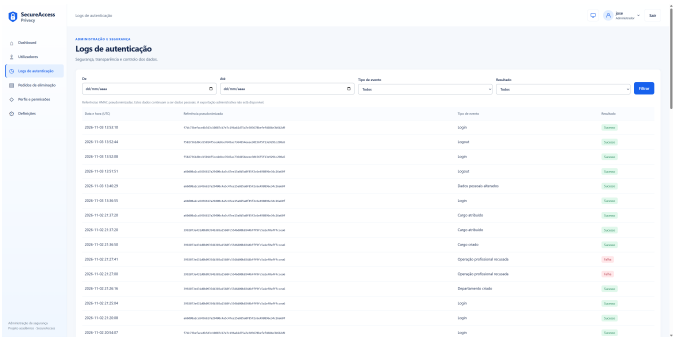


Figura 24. Consulta administrativa dos logs implementada.

A Figura 24 apresenta a interface “Logs de autenticação”, que permite ao administrador consultar os eventos relevantes para a segurança do sistema.

Cada registo apresenta uma referência pseudonimizada, o tipo de evento, a data e hora e o resultado. Estão disponíveis filtros que permitem pesquisar os eventos conservados na base de dados.

Os logs não incluem palavras-passe, códigos TOTP, segredos de autenticação ou endereços IP em bruto.

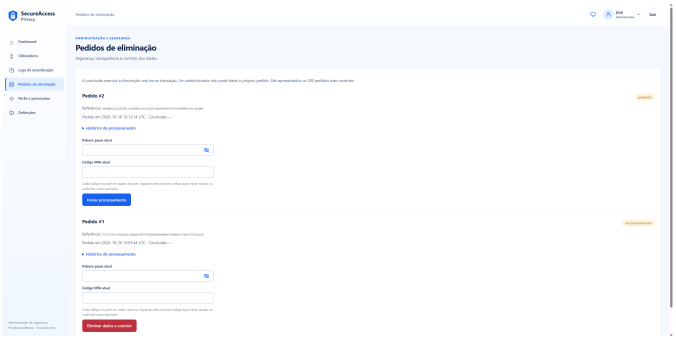


Figura 25. Gestão dos pedidos de eliminação implementada.

A Figura 25 apresenta a página “Pedidos de eliminação”, que permite ao administrador consultar e processar os pedidos submetidos pelos utilizadores.

O processo distingue três estados: *pendente*, *em processamento* e *concluído*.

A conclusão do pedido elimina a conta, as respetivas credenciais, o perfil pessoal e os eventos de auditoria associados. O histórico mínimo do pedido é conservado temporariamente, sem ligação direta à conta.

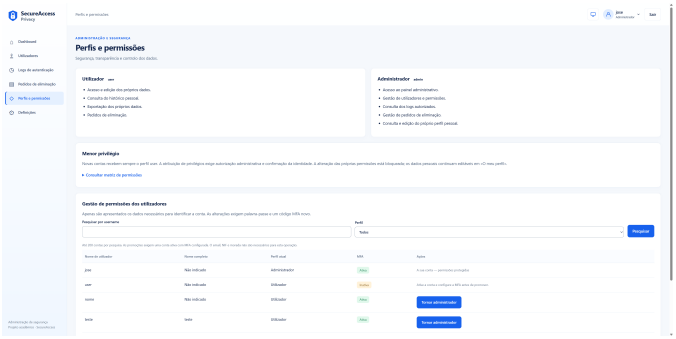


Figura 26. Interface de perfis e permissões implementada.

A Figura 26 apresenta a interface “Perfis e permissões”, que permite consultar as operações disponíveis para os perfis `user` e `admin`.

O sistema utiliza controlo de acesso baseado em perfis, com verificação das permissões no backend, sem recorrer a tabelas independentes para atribuição individual de permissões.

O administrador pode alterar o perfil de outros utilizadores, respeitando as restrições de segurança definidas na aplicação.

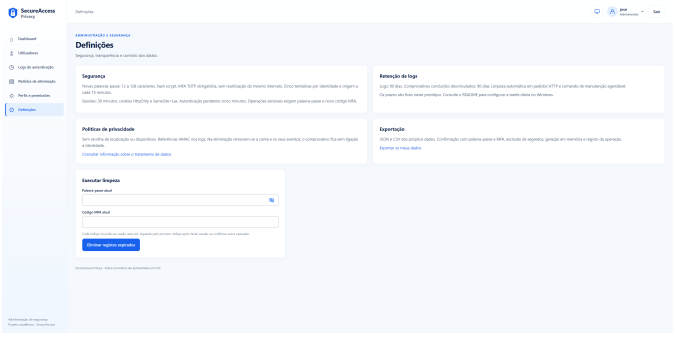


Figura 27. Interface de definições administrativas implementada.

A Figura 27 apresenta a página “Definições”, que centraliza informação relativa às políticas de segurança e privacidade aplicadas pelo sistema.

São apresentados os parâmetros relevantes para a autenticação, o controlo de acessos e a conservação de dados.

O administrador pode executar a limpeza dos registos expirados, enquanto determinados parâmetros permanecem definidos na configuração da aplicação.

E. Classificação e proteção dos dados pessoais

Para orientar o tratamento dos dados pessoais no SecureAccess Privacy, foi definida uma taxonomia de privacidade que permite classificar a informação de acordo com a sua natureza, finalidade e requisitos de proteção.

A classificação considera cinco dimensões principais: sensibilidade do dado, identificabilidade, finalidade do tratamento, período de conservação e nível de confidencialidade.

A sensibilidade representa o risco associado à exposição indevida da informação, enquanto a identificabilidade permite distinguir dados diretamente identificáveis, dados associados a uma identidade e dados pseudonimizados.

A finalidade do tratamento determina a razão pela qual cada dado é recolhido ou utilizado, nomeadamente o registo, a autenticação, a gestão da conta e as operações de segurança.

O período de conservação estabelece durante quanto tempo a informação permanece armazenada e em que condições é eliminada. O nível de confidencialidade define os perfis ou componentes autorizados a consultar ou tratar cada categoria de dados.

1) Aplicação ao modelo de dados: A aplicação destes critérios permitiu distinguir as diferentes categorias de informação tratadas pelo sistema.

A entidade `users` concentra os dados necessários à identificação e autenticação da conta, enquanto `user_profiles` armazena os dados pessoais adicionais, como nome completo, data de nascimento, género, NIF, morada, estado civil e fotografia.

A classificação inclui também os dados organizacionais, representados pelo departamento e cargo profissional do colaborador.

Embora estes atributos não constituam necessariamente categorias especiais de dados pessoais, podem contribuir para a identificação de um indivíduo quando associados à sua conta ou a outros dados.

A informação organizacional é mantida em entidades próprias e associada ao perfil pessoal através de chaves estrangeiras, com restrições de integridade referencial.

Na exportação dos dados da conta, são incluídas, quando disponíveis, informações relativas ao cargo atribuído, ao departamento associado e ao estado de atividade dessa associação.

Esta informação é obtida através das relações entre `user_profiles`, `job_positions` e `departments`, sem necessidade de duplicar os dados organizacionais no perfil pessoal.

Esta abordagem permite manter a consistência da informação e aplicar os critérios de minimização, identificabilidade e controlo de acesso aos dados organizacionais.

Estes atributos adicionais são facultativos e destinam-se à demonstração académica com dados fictícios. A sua utilização num contexto real exige a definição de uma finalidade específica e a justificação da necessidade de cada atributo.

Os dados de autenticação são considerados críticos para a segurança da conta. As palavras-passe são armazenadas sob a forma de hash e os segredos TOTP são cifrados, sem exposição destes valores nas interfaces de consulta ou exportação.

Os eventos de autenticação e segurança são armazenados em `audit_logs`, com identificadores pseudonimizados através de HMAC-SHA256. Estes registos continuam a ser considerados dados pessoais, uma vez que podem ser associados a utilizadores pelo próprio sistema.

A conservação dos logs encontra-se limitada a 90 dias, com eliminação dos registos expirados através dos mecanismos de limpeza implementados.

2) Controlo de acesso e transparência: O acesso à informação é definido segundo o princípio do menor privilégio, com distinção entre os perfis `user` e `admin`.

Cada utilizador pode consultar e gerir os seus próprios dados pessoais, enquanto as funcionalidades administrativas estão sujeitas a verificações de autorização no backend.

A transparência é concretizada através da página "Os meus dados" e do Centro de Privacidade, que disponibilizam informação sobre os dados tratados e os respetivos mecanismos de proteção.

As funcionalidades de exportação e de pedido de eliminação permitem ao utilizador exercer maior controlo sobre a informação associada à sua conta.

Desta forma, a classificação dos dados orienta as medidas de minimização, pseudonimização, confidencialidade, conservação e controlo de acesso, em conformidade com os princípios de *Privacy by Design* adotados no desenvolvimento do projeto.

F. Validação e limitações

A implementação inclui testes automatizados para os processos de autenticação, MFA, gestão de sessões, controlo de acesso, auditoria, exportação, eliminação e retenção dos dados.

Foram também desenvolvidos testes relativos às migrações da base de dados, validação dos perfis pessoais e proteção contra operações não autorizadas.

A aplicação apresenta limitações associadas ao seu caráter académico, nomeadamente a utilização de SQLite, a ausência de recuperação de MFA e a inexistência de um sistema externo de monitorização e notificação de incidentes.

O servidor Flask permite o acesso a partir de dispositivos da rede local, mas não constitui uma infraestrutura de produção.

A implementação demonstra a aplicação prática de medidas de *Privacy by Design*, sem representar uma declaração de conformidade integral com o RGPD.

XI. Repositório

Repositório disponível em: https://github.com/lcmlo/SecureAccess-Privacy

Referências

[1] M. Bento, J. L. da Glória, L. C. Lourenço, e R. de C. Ourelo, "SecureAccess — Implementação e Avaliação de um Sistema de Autenticação Multifator (MFA)," ISCTE, 2025. [Online]. Available: https://github.com/ricardo-ourelo/SecureAccess

[2] V. C. Andrade, R. D. Gomes, S. Reinehr, C. O. D. A. Freitas, and A. Malucelli, "Privacy by design and software engineering a systematic literature review," *ACM International Conference Proceeding Series*, Nov. 2022. [Online]. Available: https://doi.org/10.1145/3571473.3571480

[3] A. Cavoukian, "Privacy by Design The 7 Foundational Principles Implementation and Mapping of Fair Information Practices." [Online]. Available: https://student.cs.uwaterloo.ca/~cs492/papers/7foundationalprinciples_longer.pdf

[4] European Parliament and Council of the European Union, "General Data Protection Regulation," 2016. [Online]. Available: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A02016R0679-20160504

[5] NIST, "NIST PRIVACY FRAMEWORK," 2020. [Online]. Available: https://doi.org/10.6028/NIST.CSWP.01162020

[6] OWASP, "Logging Cheat Sheet," [Online]. Available: https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html

[7] J. Glöckler, J. Sedlmeir, M. Frank, and G. Fridgen, "A Systematic Review of Identity and Access Management Requirements in Enterprises and Potential Contributions of Self-Sovereign Identity," *Business and Information Systems Engineering*, vol. 66(4), pp. 421–440, 2024.

[8] Okta, "Multifactor authentication," [Online]. Available: https://developer.okta.com/docs/concepts/mfa/

[9] Keycloak, "Server Administration Guide," [Online]. Available: https://www.keycloak.org/docs/26.8.0/server_admin/

[10] Okta, "System Log," [Online]. Available: https://help.okta.com/en-us/Content/Topics/reports/reports_syslog.htm

[11] Okta, "Data retention," [Online]. Available: https://developer.okta.com/docs/reference/system-log-query/#data-retention

[12] Okta, "Role permissions," [Online]. Available: https://help.okta.com/en-us/content/topics/security/custom-admin-role/about-role-permissions.htm

[13] Okta, "Learn about administrators," [Online]. Available: https://help.okta.com/en-us/content/topics/security/administrators-learn-about-admins.htm

[14] Okta, "Permissions," [Online]. Available: https://developer.okta.com/docs/api/openapi/okta-management/guides/permissions

[15] Parlamento Europeu e Conselho da União Europeia, "Diretiva (UE) 2022/2555 (NIS2)," 2022. [Online]. Available: https://eur-lex.europa.eu/eli/dir/2022/2555/oj